

Helpdesk dla sklepu internetowego

Projekt systemu Helpdesk opiera się na rzeczach omawianych na wykładzie, głównie podziale na komponenty oraz triadzie CIA. System służy do obsługi zgłoszeń klientów sklepu internetowego.

1. Propozycja architektury

Frontend – aplikacja webowa dla użytkownika. Oddzielenie ma sens, bo użytkownik ma dostęp tylko do interfejsu.

Backend – obsługuje logikę i dostęp do danych. Ma sens, bo wszystko można kontrolować po stronie serwera.

Baza danych – przechowuje dane. Oddzielenie ogranicza dostęp do danych.

Auth – logowanie i role użytkowników. Pozwala kontrolować kto ma do czego dostęp.

Email – wysyła powiadomienia do użytkowników.

Komunikacja: frontend ↔ backend (HTTPS), backend ↔ baza (SQL), backend ↔ email.

2. Uzasadnienie z perspektywy bezpieczeństwa

Frontend: możliwy XSS. Walidacja danych i HTTPS mają sens, bo chronią przed złośliwym kodem i przechwyceniem danych.

Backend: ryzyko dostępu do cudzych danych. Kontrola uprawnień ma sens, bo backend sprawdza uprawnienia użytkownika.

Baza danych: ryzyko wycieku. Ograniczenie dostępu i backupy mają sens, bo chronią dane przed utratą i dostępem osób nieuprawnionych.

Auth: ryzyko przejęcia konta. Hashowanie haseł ma sens, bo nawet po wycieku nie da się łatwo odczytać hasła.

Email: ryzyko wysłania danych do złej osoby. Ograniczenie treści maili ma sens, bo zmniejsza ilość wrażliwych danych poza systemem.

3. Triada CIA (z wykładu)

Poufność: dane klientów i zgłoszeń muszą być chronione przed dostępem osób trzecich.

Integralność: dane nie mogą być zmienione przez nieuprawnione osoby.

Dostępność: system powinien działać cały czas, aby klienci mogli zgłaszać problemy.

Trade-off: więcej zabezpieczeń może spowolnić system.

4. Użytkownicy i dane

Użytkownicy:

- 1 Klient – zgłasza problemy i widzi tylko swoje zgłoszenia
- 2 Pracownik – obsługuje zgłoszenia
- 3 Administrator – zarządza systemem

Dane:

- 1 Dane osobowe (imię, email, telefon)
- 2 Numery zamówień
- 3 Treść zgłoszeń
- 4 Dane logowania

Najważniejsze do ochrony są dane osobowe i dane logowania, ponieważ mogą zostać użyte do przejęcia konta lub naruszenia prywatności użytkownika.

5. Pytania

- 1 Jak upewnić się, że użytkownik widzi tylko swoje dane?
- 2 Jak ograniczyć dostęp pracowników tylko do potrzebnych danych?
- 3 Jak wykrywać próby nadużyć w systemie?